

Top 10 web hacking techniques of 2023 - nominations open



James Kettle

Director of Research

[@albinowax](#)



Published: Tuesday, 9 January 2024 at 14:33 UTC

Updated: Monday, 20 May 2024 at 14:00 UTC



Update: The results are in! [Check out the final top ten here](#) or [scroll down to view all nominations](#)

Over the last year, numerous security researchers have shared their discoveries with the community through blog posts, presentations and whitepapers. Many of these posts contain innovative ideas waiting for the right person to adapt and combine them into new discoveries in future.

However, the sheer volume can leave good techniques overlooked and quickly forgotten. Since 2006, the community has come together every year to help by building two valuable resources

- A full list of all notable web security research from the last year
- A refined list of the top ten most valuable pieces of work

Check out the [full project archive](#) for past nominees and winners. Read on to find out how you can make your nominations from 2023!

This year, we'll target the following timeline:

Timeline

- Jan 9-21: Collect community nominations
- Jan 23-30: Community vote to build shortlist of top 15
- Feb 1-13: Expert panel vote on final 15
- Feb 15: Results announced!

What should I nominate?

The aim is to highlight research containing novel, practical techniques that can be re-applied to different systems. Individual vulnerabilities like log4shell are valuable at the time but age relatively poorly, whereas underlying techniques such as JNDI Injection can often be reapplied to great effect. Nominations can also be refinements to already-known attack classes, such as Exploiting XXE with Local DTD Files. For further examples, you might find it useful to check out previous year's top 10s.

How to make a nomination

To submit, simply provide a URL to the research, and an optional brief comment explaining what's novel about the work. Feel free to make as many nominations as you like, and nominate your own work if you think it's worthy!

[Click here to submit a nomination](#)

Please note that I'll filter out nominations that are non-web focused, just tools, or not clearly innovative to keep the number of options in the community vote manageable. We don't collect email addresses - to get notified when the voting stage starts, follow [@PortSwiggerRes](#) or [@albinowax@infosec.exchange](#).

Nominations

I've made a few nominations myself to get things started, and I'll update this list with fresh community nominations every few days. In the spirit of excessive automation, I've included AI-assisted summaries of each entry.

- [Ransacking your password reset tokens](#)
Brute-force attack on Ruby on Rails applications using the Ransack library, to exfiltrate password reset tokens through character-by-character prefix matching via search filters.
- [mTLS: When certificate authentication is done wrong](#)
Vulnerabilities in mutual TLS leading to user impersonation, privilege escalation, and information leakage.
- [Smashing the state machine: the true potential of web race conditions](#)
Concept of "everything is multi-step" for web [race conditions](#), expanding the traditional limit-overflow attack scope by exploiting hidden sub-states within web applications and introducing a jitter-resistant "single-packet attack".
- [Bypass firewalls with of-CORs and typo-squatting](#)
Exploitation of [Cross-Origin Resource Sharing \(CORS\)](#) misconfigurations on internal networks using typo-squatting domains to probe for and exfiltrate sensitive data without violating bug bounty rules.
- [RCE via LDAP truncation on hg.mozilla.org](#)
Achieved Remote Code Execution (RCE) on Mozilla's server by exploiting LDAP query truncation with NULL byte injection to bypass input sanitization, enabling [command injection](#).

- [Cookie Bugs - Smuggling & Injection](#)
Exploiting inconsistent parsing of dquoted cookie values, leading to cookie smuggling, and how incorrect delimiters allow cookie injection, enabling CSRF token spoofing and potential authentication bypasses.
- [OAuth 2.0 Redirect URI Validation Falls Short, Literally](#)
OAuth exploitation via path confusion.
- [Prototype Pollution in Python](#)
Class Pollution in Python via recursive merge functions manipulating `\_\_class\_\_` special attributes.
- [Pretalx Vulnerabilities: How to get accepted at every conference](#)
Leveraging Python's site-specific configuration hooks for .pth files to gain arbitrary code execution via limited file write vulnerability.
- [From Akamai to F5 to NTLM... with love.](#)
Leveraging HTTP request smuggling and cache poisoning via Akamai and F5 BIGIP systems to redirect and steal sensitive data including authorization tokens and NTLM credentials.
- [can I speak to your manager? hacking root EPP servers to take control of zones](#)
Exploiting XXE vulnerabilities in EPP servers and local file disclosure in CoCCA Registry Software to gain control of entire ccTLD zones.
- [Blind CSS Exfiltration: exfiltrate unknown web pages](#)
Using CSS :has selector to perform blind exfiltration of sensitive data without JavaScript.
- [Server-side prototype pollution: Black-box detection without the DoS](#)
Leveraging non-destructive techniques like JSON response manipulation and CORS header injection for the safe black-box detection of server-side prototype pollution.
- [Tricks for Reliable Split-Second DNS Rebinding in Chrome and Safari](#)
Exploiting delayed DNS responses with Safari and Chrome's prioritization of IPv6 to perform split-second DNS rebinding attacks.
- [HTML Over the Wire](#)
Exploiting "HTML Over the Wire" libraries' features for CSRF token leakage via cross-origin POST requests with injected links.
- [SMTP Smuggling - Spoofing E-Mails Worldwide](#)
Exploiting differences in SMTP protocol interpretation to bypass SPF and DMARC email validation checks and send spoofed emails.
- [DOM-based race condition: racing in the browser for fun - RyotaK's Blog](#)
Exploiting race conditions in AngularJS applications by delaying the loading of AngularJS with a connection pool exhaustion attack to enable DOM-based XSS via pasted clipboard data with ng-directives.
- [You Are Not Where You Think You Are, Opera Browsers Address Bar Spoofing Vulnerabilities](#)
Address bar spoofing techniques in Opera browsers, exploiting features like intent URLs, extension

updates, and fullscreen mode

- [CVE-2022-4908: SOP bypass in Chrome using Navigation API](#)
Abusing Navigation API's `navigation.entries()` to leak the navigation history array from cross-origin windows.
- [SSO Gadgets: Escalate \(Self-\)XSS to ATO](#)
Leveraging SSO gadgets in OAuth2/OIDC implementations to convert Self-XSS to ATO.
- [Three New Attacks Against JSON Web Tokens](#)
Novel JWT implementation flaws
- [Introducing wrapwrap: using PHP filters to wrap a file with a prefix and suffix](#)
Leveraging PHP filter chains to prepend and append arbitrary content to file data, facilitating SSRF to RCE and local file inclusion attacks.
- [PHP filter chains: file read from error-based oracle](#)
Combining memory exhaustion and encoding translations via PHP filter chains to perform error-based local file content leakage.
- [SSRF Cross Protocol Redirect Bypass](#)
Bypassing SSRF filters using cross-protocol redirection from HTTPS to HTTP.
- [A New Vector For "Dirty" Arbitrary File Write to RCE](#)
Leveraging uWSGI configuration parsing for remote code execution via a tainted PDF utilizing polymorphic content and automatic reload behavior.
- [How I Hacked Microsoft Teams and got \\$150,000 in Pwn2Own](#)
RCE in Microsoft Teams through a combination of bugs including XSS via chat message, lack of context isolation, and JS execution outside the sandbox.
- [AWS WAF Clients Left Vulnerable to SQL Injection Due to Unorthodox MSSQL Design Choice](#)
Terminating MSSQL queries with ' ' instead of ';' to bypass AWS WAF.
- [BingBang: AAD misconfiguration led to Bing.com results manipulation and account takeover](#)
Leveraging AAD multi-tenant misconfiguration for unauthorized application access leading to Bing.com result manipulation and XSS attacks.
- [MyBB Admin Panel RCE CVE-2023-41362](#)
Exploiting catastrophic backtracking in MyBB's admin panel regex to bypass template safety checks and execute arbitrary code.
- [Source Code at Risk: Critical Code Vulnerability in CI/CD Platform TeamCity](#)
Bypassing TeamCity server authentication check with unsanitized input handling for request interceptor pre-handling paths.
- [Code Vulnerabilities Put Skiff Emails at Risk](#)
Bypassing Skiff's HTML sanitization to achieve XSS and steal decrypted emails.

- [How to break SAML if I have paws?](#)
Attacking SAML implementations through XML signature wrapping, plaintext injections, signature exclusion, flawed certificate validation, and more.
- [JMX Exploitation Revisited](#)
Leveraging JMX StandardMBean and RequiredModelMBean for RCE by dynamic MBean creation and arbitrary method invocation.
- [Java Exploitation Restrictions in Modern JDK Times](#)
Bypassing Java deserialization gadget execution restrictions in modern JDKs using JShell API for JDK versions ≥ 15 and `--add-opens` with Reflection for JDK ≥ 16 .
- [Exploiting Hardened .NET Deserialization](#)
Bypassing .NET deserialization security using novel gadget chains.
- [Unserializable, but unreachable: Remote code execution on vBulletin](#)
Exploiting class autoloading in PHP for remote code execution by including arbitrary files using crafted unserialize payloads in vBulletin.
- [Cookieless DuoDrop: IIS Auth Bypass & App Pool Privesc in ASP.NET Framework](#)
Bypassing IIS authentication and impersonating parent application pool identities in ASP.NET using double cookieless pattern.
- [Hunting for Nginx Alias Traversals in the wild](#)
Leveraging Nginx alias misconfigurations for directory traversal attacks.
- [DNS Analyzer - Finding DNS vulnerabilities with Burp Suite](#)
Using Burp Collaborator with DNS Analyzer extension to identify DNS vulnerabilities that facilitate Kaminsky-style DNS cache poisoning attacks.
- [Oh-Auth - Abusing OAuth to take over millions of accounts](#)
Manipulating OAuth token verification logic to facilitate account takeovers.
- [nOAuth: How Microsoft OAuth Misconfiguration Can Lead to Full Account Takeover](#)
Leveraging mutable and unverified "email" claim within Microsoft Azure AD OAuth applications for account takeover.
- [One Scheme to Rule Them All: OAuth Account Takeover](#)
Exploiting OAuth with app impersonation via custom scheme hijacking for account takeover.
- [Exploiting HTTP Parsers Inconsistencies](#)
Exploiting HTTP parser inconsistency for ACL bypass and cache poisoning.
- [New ways of breaking app-integrated LLMs](#)
Indirect prompt injection attacks on application-integrated LLMs enabling remote control, data exfiltration, and persistent compromise.
- [State of DNS Rebinding in 2023](#)
Advancements and trends in DNS rebinding attacks, examining their effectiveness against modern

- [Fileless Remote Code Execution on Juniper Firewalls](#)
PHP environment variable manipulation technique that bypasses the need for a file upload, exploiting the auto_prepend_file PHP feature and the Appweb web server's handling of environment variables and stdin.
- [Thirteen Years On: Advancing the Understanding of IIS Short File Name \(SFN\) Disclosure!](#)
Revealing full file names in IIS that contain ~DIGIT patterns using file name enumeration techniques.
- [Metamask Snaps: Playing in the Sand](#)
Exploiting untrusted code execution via JSON sanitization bypass within Metamask Snaps environment.
- [Uncovering a crazy privilege escalation from Chrome extensions](#)
Escalation to arbitrary code execution via chrome:// URL XSS and filesystem: protocol abuse in Chrome extensions on ChromeOS.
- [Code Vulnerabilities Put Proton Mails at Risk](#)
DOMPurify sanitization bypass in Proton Mail via svg to proton-svg renaming leading to XSS.
- [Hacking into gRPC-Web](#)
Exploiting gRPC-Web to discover hidden services and parameters, leading to vulnerabilities like SQL injection.
- [Yelp ATO via XSS + Cookie Bridge](#)
Achieving Account Takeover (ATO) on yelp.com and biz.yelp.com through Cross-Site Scripting (XSS) coupled with Cookie Bridging.
- [HTTP Request Splitting vulnerabilities exploitation](#)
Leveraging nginx misconfigurations to perform HTTP request splitting via control characters in variables.
- [XSS in GMAIL Dynamic Email](#)
Exploitation of CSS parsing in Gmail's AMP for Email allowed injection of meta tag for potential phishing, bypassing strict CSP with no effective XSS.
- [Azure B2C Crypto Misuse and Account Compromise](#)
Extracting public RSA keys to craft valid OAuth refresh tokens and compromise Azure AD B2C user accounts.
- [Compromising F5 BIGIP with Request Smuggling](#)
Exploiting the AJP protocol with HTTP request smuggling to bypass authentication and execute arbitrary system commands on F5 BIG-IP systems identified by CVE-2023-46747.
- [EmojiDeploy: Smile! Your Azure web service just got RCE'd](#)
Exploiting same-site misconfiguration and origin check bypass in Azure Kudu SCM to achieve RCE through CSRF via ZIP file deployments.

- [One Supply Chain Attack to Rule Them All](#)
Exploiting self-hosted GitHub Action runners for persistent access and executing arbitrary code on internal GitHub infrastructure to compromise CI/CD secrets and potentially tamper with GitHub's runner images for supply chain attacks.
- [draw.io CVEs](#)
OAuth token leakage due to a whitespace bypass in URL validation.
- [Leaking Secrets From GitHub Actions: Reading Files And Environment Variables, Intercepting Network/Process Communication, Dumping Memory](#)
Leveraging command injection in GitHub Actions to read environment variables and files, intercept network and process communication, and dump memory for extracting secrets.
- [fuzzuli](#)
Dynamic generation of wordlists based on domain name transformations to discover backup files.
- [The GitHub Actions Worm: Compromising GitHub Repositories Through the Actions Dependency Tree](#)
Leveraging GitHub Actions' dependency tree to spread malware recursively across repositories using compromised Actions.
- [From an Innocent Client-Side Path Traversal to Account Takeover](#)
Leveraging client-side path traversal in fetch requests and OAuth error redirection for account takeover.
- [tRPC Security Research: Hunting for Vulnerabilities in Modern APIs](#)
Leveraging Type errors and improperly secured trpc-panel endpoints to identify and exploit tRPC API vulnerabilities.
- [Chained to hit: Discovering new vectors to gain remote and root access in SAP Enterprise Software](#)
Exploiting SAP Enterprise via the P4 protocol and JNDI reference injection.
- [AWS WAF Bypass: invalid JSON object and unicode escape sequences](#)
Bypassing AWS WAF via invalid JSON with duplicated parameter names.
- [Cookie Crumbles: Breaking and Fixing Web Session Integrity](#)
Exposing session integrity vulnerabilities due to implementation or specification inconsistencies across browsers and web frameworks.
- [Memcached Command Injections at Pylibmc](#)
Exploiting Flask-Session with Memcached command injection utilizing crc32 collision and python pickle deserialization for RCE.

Top 10 Hacking Techniques

← [Back to all articles](#)

Related Research



Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering



 [Follow us](#)

© 2026 PortSwigger Ltd.

